

IT Vendor Risk Assessment Report

Service: Acme Cloud Services

Generated: 2026-07-28 02:15 | Classification: INTERNAL CONFIDENTIAL | Framework: Murdoch University Risk Management Framework

Assessment scope: Murdoch University internal policy documents and HECVAT template only. No external frameworks (NIST, ISO, GDPR etc.) applied. Risk scored via Murdoch RMF likelihood × impact matrix on assessed controls only. Controls marked INSUFFICIENT_EVIDENCE reflect policy knowledge-base coverage gaps, not vendor compliance status.

1. Executive Summary

Metric	Value
Total Controls	195
Assessed (policy match)	172
Insufficient Evidence	23
Coverage	88.2%
Compliant	113
Partial	41
Gaps	18
Extreme Risks	0
High Risks	14
■■ RMF Score (assessed)	2.64
■■ Overall Risk Band	MEDIUM

2. Murdoch RMF Risk Legend

RMF Level	Likelihood × Impact	Action
EXTREME	High L × High I	Immediate action required
HIGH	High L × Med I	Senior management attention
MEDIUM	Med L × Med I	Management responsibility
MINOR	Low L × Med I	Monitor and review
LOW	Low L × Low I	Routine procedures

3. Risk by Section (Assessed Controls Only)

Section	Avg RMF Score	Band
Third-Party Management	3.8	HIGH

LLM Privileges	3.4	MEDIUM
AI Policy	3.2	MEDIUM
Data Security	3.16	MEDIUM
Access Control	3.0	MEDIUM
AI/ML Data Separation	2.8	MEDIUM
Firewall & IDS/IPS	2.73	MEDIUM
Documentation	2.71	MEDIUM
Vulnerability Management	2.67	MEDIUM
Application Security	2.62	MEDIUM
Data Center	2.57	MEDIUM
Incident Response	2.5	MEDIUM
AI Security	2.5	MEDIUM
AI Governance	2.4	MINOR
Change Management	2.27	MINOR
Policies, Processes & Procedures	2.23	MINOR
IT Accessibility	2.08	MINOR
Consulting	2.0	MINOR
Operational & Emerging Tech	1.83	MINOR

■ HIGH Risks — Senior Management Attention

- [DOCU-03] The vendor's response contradicts the requirement for a recent SSAE 18/SOC 2 audit. The provided evidence is absent, further compounding the gap.
- [DCTR-14] Vendor does not meet Murdoch University's policy requiring MFA for administrative accounts. This represents a significant risk as it leaves systems vulnerable to unauthorized access.
- [AIML-03] The vendor's response directly contradicts Murdoch University's policy requirement (Context A) that mandates vetting, validation, and verification of ML training data. This represents a significant risk.
- [ITAC-06] The vendor simply stated 'Yes' without providing a link to the VPAT or ACR. Context A requires a *reference* to the document (Web Link to Accessibility Statement or VPAT). While the response aligns with the requirement, it is insufficient.
- [THRD-01] Vendor evidence is lacking. The SOC 2 report does not provide specific details about the security assessments performed, their scope, or the methodologies used. Murdoch University requires demonstrable evidence of these controls.
- [THRD-04] The vendor's response is a simple 'Yes,' but lacks detail regarding the scope, processes, and documentation of their strategy. Context A requires addressing national or regional regulations, which is not addressed.
- [APPL-05] The vendor's response is affirmative but lacks detail regarding the specific implementation of separation of duties. Murdoch University policy (Policy 1 and Policy 3) requires a detailed process. The vendor's response is insufficient.
- [AAAI-11] The vendor's 'Yes' response is insufficient. Murdoch University policy (Policy 1 & Policy 3) requires a detailed explanation of log retention periods (12 months), protection mechanisms (SIEM forwarding), and data handling procedures.
- [DATA-11] Vendor confirmation lacks specific details regarding the scope of 'all' operating system software, utilities, security software, application software, and data files. Without further clarification and evidence, this remains a high risk.

- [DCTR-06] The vendor's 'Yes' response does not provide sufficient detail to confirm full compliance. Policy A states that a physical barrier *fully* encloses the space. The vendor has not demonstrated this is t
- [DCTR-10] Vendor response is a simple 'Yes' without detail on the testing frequency or scope. Murdoch University policy (Policy 5) requires documented disaster recovery plans that are regularly tested. The vend
- [FIDP-01] CONTEXT B does not provide sufficient detail to corroborate the vendor's claim. While they state they use a SPI firewall, it doesn't demonstrate how this aligns with Murdoch University's requirements
- [VULN-01] The vendor's response is a simple 'Yes,' but CONTEXT A requires specifics about the scanning process (authenticated user account) and remediation. The SOC 2 report doesn't provide sufficient detail to
- [AIPL-02] CONTEXT A requires documentation and policies around measuring AI risk. Vendor response is a simple 'Yes' without supporting evidence or details of the measurement process. The SOC 2 report mentions a

4. Detailed Findings

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
DOCU-01	Documentat ion	COM PLIA NT	COMPLI ANT	COMPL IANT	HIGH	4	3		2.13. Critical IT systems must have disaster recovery plans that are documented and regularly tested.	
DOCU-02	Documentat ion	COM PLIA NT	COMPLI ANT	COMPL IANT	HIGH	4	3		2.13. Critical IT systems must have disaster recovery plans that are documented and regularly tested.	
DOCU-03	Documentat ion	GAP	GAP	GAP	HIGH	4	3	The vendor's response contradicts the requirement for a recent SSAE 18/SOC 2 audit. The provided evidence is absent, further compounding the gap.		Require the vendor to provide documentation of a current, executed within the past year Attestation of Compliance (AoC) or Report on Compliance (RoC).
DOCU-04	Documentat ion	GAP	NOT_AS SESSED	GAP	MINOR	3	2	The vendor's response contradicts HECVAT's requirement for adherence to a recognized security framework (e.g., NIST CSF, CIS Controls, ISO 27001). There is no relevant policy in Context A to assess this.		
DOCU-05	Documentat ion	COM PLIA NT	COMPLI ANT	COMPL IANT	LOW	3	1		Control: OPEM-03 Section: Operational & Emerging Tech Question: Can you provide overall system and/or application architecture diagrams including a full description of the data communications architecture for all components of the system?	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
DOCU-06	Documentat ion	COM PLIA NT	COMPLI ANT	COMPL IANT	MINOR	3	2			
DOCU-07	Documentat ion	COM PLIA NT	COMPLI ANT	COMPL IANT	MINOR	3	2		Policy 1: hecvat_template Privacy Documentation - Control: PDOC-03 - Question: Does your employee onboarding and offboarding policy include training of employees on information security and data privacy?	
ITAC-05	IT Accessibility	COM PLIA NT	COMPLI ANT	COMPL IANT	LOW	3	1		VPAT can also be added as an attachment	
ITAC-06	IT Accessibility	PART IAL	COMPLI ANT	PARTIA L	HIGH	4	3	The vendor simply stated 'Yes' without providing a link to the VPAT or ACR. Context A requires a *reference* to the document (Web Link to Accessibility Statement or VPAT). While the response aligns with HECVAT's compliant answer, it doesn't meet Murdoch University's policy requirement for documentation and verification.	Web Link to Accessibility Statement or VPAT	Request vendor provide a link to the VPAT/ACR for review. Verify the date of last update is within the past 12 months.
ITAC-07	IT Accessibility	COM PLIA NT	COMPLI ANT	COMPL IANT	MEDIU M	4	2		Control: ITAC-07 Section: IT Accessibility Question: Will your company agree to meet your stated accessibility standard or WCAG 2.1 AA as part of your contractual agreement for the solution?	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
ITAC-08	IT Accessibility	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2		Control: ITAC-08 Section: IT Accessibility Question: Does the solution substantially conform to WCAG 2.1 AA?*	
ITAC-09	IT Accessibility	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2		Control: ITAC-09 Section: IT Accessibility Question: Do you have a documented and implemented process for reporting and tracking accessibility issues?*	
ITAC-10	IT Accessibility	GAP	PARTIAL	PARTIAL	MINOR	3	2	The vendor's simple 'Yes' response does not provide sufficient detail to demonstrate documented support. Context A requires a description of the processes and procedures involved. Vendor evidence is lacking.	Policy 2: hecvat_template IT Accessibility - Control: ITAC-09 - Question: Do you have a documented and implemented process for reporting and tracking accessibility issues?	Request detailed documentation outlining the accessibility features and supporting processes from the vendor.
ITAC-11	IT Accessibility	COMPLIANT	COMPLIANT	COMPLIANT	LOW	3	1		Has a third-party expert conducted an audit of the most recent version of your solution?	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
ITAC-12	IT Accessibility	COMPLIANT	COMPLIANT	COMPLIANT	LOW	3	1		Control: ITAC-12 Section: IT Accessibility Question: Do you have a documented and implemented process for verifying accessibility conformance?	
ITAC-13	IT Accessibility	COMPLIANT	COMPLIANT	COMPLIANT	LOW	3	1		Control: ITAC-13 Section: IT Accessibility Question: Have you adopted a technical or legal standard of conformance for the solution?	
ITAC-14	IT Accessibility	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Control: ITAC-14 Section: IT Accessibility Question: Can you provide a current, detailed accessibility roadmap with delivery timelines?	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
ITAC-15	IT Accessibility	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Control: ITAC-15 Section: IT Accessibility Question: Do you expect your staff to maintain a current skill set in IT accessibility? Guidance: How do you ensure that your professional staff keeps current with digital accessibility laws and best practices? Is your staff able to evaluate and test this product with assistive technologies such as a screen reader or alternative input devices? Examples of staff certification may include IAAP certifications < https://www.accessibilityassociation.org/s/professional-certifications > or §508 Trusted Tester < https://www.dhs.gov/trusted-tester >	
ITAC-16	IT Accessibility	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Control: ITAC-16 Section: IT Accessibility Question: Do you have documented processes and procedures for implementing accessibility into your development lifecycle?	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
ITAC-17	IT Accessibility	GAP	COMPLIANT	PARTIAL	MINOR	3	2	The vendor's response is a simple 'Yes,' but does not provide any supporting evidence or detail regarding how the application meets accessibility requirements. Context A requires specific details about keyboard functionality. The SOC 2 report doesn't offer sufficient insight into this control.	Control: ITAC-17 Section: IT Accessibility Question: Can all functions of the application or service be performed using only the keyboard? Compliant Response: Yes	Request further documentation from the vendor detailing the implemented accessibility features and testing procedures to demonstrate compliance with Murdoch University's IT Accessibility policy (ITAC-17).
ITAC-18	IT Accessibility	GAP	GAP	INSUFFICIENT EVIDENCE	MINOR	3	2	The vendor's response aligns with Murdoch University's policy (Context A - ITAC-18) which requires a clear statement on whether accessibility features are implemented through dedicated modes or alternative interfaces. The SOC 2 report does not provide sufficient evidence to confirm this assertion.	Control: ITAC-18 Section: IT Accessibility Question: Does your product rely on activating a special "accessibility mode," a "lite version," or using an alternate interface (including "overlay" or AI-based alternates) for accessibility purposes?	Request further clarification from the vendor regarding the specific mechanisms used for accessibility, if any, and how they align with Murdoch University's requirements outlined in ITAC-18.
THRD-01	Third-Party Management	GAP	COMPLIANT	PARTIAL	HIGH	4	3	Vendor evidence is lacking. The SOC 2 report does not provide specific details about the security assessments performed, their scope, or the methodologies used. Murdoch University requires demonstrable evidence of these assessments to ensure alignment with its policy.		Request detailed documentation outlining the vendor's third-party security assessment program, including frequency, scope, and methodology.
THRD-02	Third-Party Management	COMPLIANT	COMPLIANT	COMPLIANT	HIGH	4	3			

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
THRD-03	Third-Party Management	COMPLIANT	COMPLIANT	COMPLIANT	EXTREME	4	4		PTHP-01: Control: PTHP-01 Section: Privacy Third Parties Question: Do you have contractual agreements with third parties that require them to maintain standards and to comply with all regulatory requirements?	
THRD-04	Third-Party Management	GAP	PARTIAL	PARTIAL	HIGH	4	3	The vendor's response is a simple 'Yes,' but lacks detail regarding the scope, processes, and documentation of their strategy. Context A requires addressing national or regional regulations, which isn't mentioned. The SOC 2 report doesn't provide sufficient evidence to confirm a robust strategy beyond basic change management.	Make sure you address any national or regional regulations.	Request further details about the vendor's third-party management strategy, including documented processes, risk assessments, and compliance with relevant regulations.
THRD-05	Third-Party Management	PARTIAL	PARTIAL	PARTIAL	MINOR	3	2	The vendor's response references a 'change management policy,' but doesn't detail how this policy specifically addresses hardware supply chain management (e.g., export licensing, equipment security). Murdoch requires a documented process covering these aspects as per Policy 1.	Policy 1: hecvat_template Third-Party Management - Control: THRD-05 - Guidance: Make sure you address any national or regional regulations.	Request further details on the change management policy and its specific application to hardware supply chain risk management, including documentation of compliance with relevant regulations.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
CONS-01	Consulting	GAP	COMPLIANT	PARTIAL	MEDIUM	4	2	The vendor's response aligns with the policy requirement (Policy 1 & 2) of requiring legitimate business need for IT resource access. However, without further evidence demonstrating that a legitimate business need has been assessed and documented, it is considered partially compliant. The SOC 2 report does not provide sufficient detail to confirm this.	10.5.7 All contractors, consultants, or other non-employees of Murdoch University will only be given appropriate IT resource access privileges if an IT resource owner, or their designee, determines there is a legitimate business need.	Request additional documentation from the vendor outlining the process for determining legitimate business needs and documenting these decisions prior to granting access.
CONS-02	Consulting	GAP	GAP	INSUFFICIENT_EVIDENCE	HIGH	4	3	The vendor's response contradicts Murdoch University's policy requiring consultants to receive training on sensitive data handling (PRPO-07 and PRPO-08). The vendor evidence does not corroborate this claim.		Require the vendor to provide documentation demonstrating that consultants have received appropriate training as per Murdoch University's policies.
CONS-03	Consulting	GAP	GAP	INSUFFICIENT_EVIDENCE	EXTREME	4	4	The vendor's response indicates a lack of data encryption at rest, which contradicts Murdoch University's policy requiring secure data handling (DATA-18 and 4.3.2 in Context A). This poses a significant risk to sensitive institutional data.	DATA-18	Require the vendor to implement and document a robust data encryption strategy for all data stored with them, including specifying the encryption method and key management practices.
CONS-04	Consulting	GAP	GAP	INSUFFICIENT_EVIDENCE	HIGH	4	3	Murdoch University policy (Policy 1 and Policy 2) mandates the use of encrypted authentication mechanisms and restricts modification of production data. The vendor's response indicates a lack of source IP address-based access restrictions, directly contradicting these policies. This creates a significant risk to data security.		Require the vendor to implement source IP address-based access controls to align with Murdoch University's ICT Security Standards and prevent unauthorized access.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
CONS-05	Consulting	GAP	COMPLIANT	PARTIAL	MINOR	3	2	The vendor's response aligns with the HECVAT compliant response of 'No'. However, Murdoch University policy (Context A) does not explicitly state a requirement regarding on-premises consulting. Therefore, while aligned with HECVAT, there is no documented policy to assess against.		
CONS-06	Consulting	COMPLIANT	COMPLIANT	COMPLIANT	LOW	1	1		10.5.7 All contractors, consultants, or other non-employees of Murdoch University will only be given appropriate IT resource access privileges if an IT resource owner, or their designee, determines there is a legitimate business need.	
CONS-07	Consulting	GAP	COMPLIANT	PARTIAL	MINOR	3	2	CONTEXT A states that all contractors, consultants, or other non-employees require a user account. The vendor's response indicates they do not require one, which contradicts this policy requirement. While the SOC 2 report mentions independence and limitations of scope, it doesn't confirm compliance with Murdoch University's policies.		Request clarification from the vendor regarding their process for providing IT resources to consultants and ensure alignment with Murdoch University's ICT Security Standard 10.5.7.
CONS-08	Consulting	GAP	NOT_ASSESSED	GAP	MINOR	3	2	The vendor did not provide a response to the question regarding data transfer. Murdoch University policy (PDAT-04) requires knowledge of any institutional data shared outside the US. Without a response, it's impossible to assess compliance.		Request clarification from the vendor on their data handling practices and whether they will transfer any institutional data.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
CONS-09	Consulting	GAP	GAP	GAP	MINOR	3	2	The vendor did not provide an answer to the question regarding remote access needs. Murdoch University policy (Context A) requires a legitimate business need and prompt disabling of privileges for contractors. Without an affirmative response indicating such a need and planned limitations, this control is not met.	10.5.7 All contractors, consultants, or other non-employees of Murdoch University will only be given appropriate IT resource access privileges if an IT resource owner, or their designee, determines there is a legitimate business need. These privileges must be	Request clarification from the vendor regarding their remote access requirements and proposed controls to ensure compliance with Murdoch University's policies.
APPL-01	Application Security	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2			
APPL-02	Application Security	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2		Are you using a web application firewall (WAF)?*	
APPL-03	Application Security	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2		Are only currently supported operating system(s), software, and libraries leveraged by the system(s)/ application(s) that will have access to institution's data?	
APPL-04	Application Security	COMPLIANT	COMPLIANT	COMPLIANT	LOW	3	1		Compliant Response: Yes	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
APPL-05	Application Security	PARTIAL	COMPLIANT	PARTIAL	HIGH	4	3	The vendor's response is affirmative but lacks detail regarding the specific implementation of separation of duties. Murdoch University policy (Policy 1 and Policy 3) requires a detailed process. The SOC 2 report does not provide sufficient evidence to confirm the effectiveness of this control.	Control: APPL-05	Request further documentation detailing the application's separation of duties model, including roles, responsibilities, and access controls.
APPL-06	Application Security	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2		Control: APPL-06 Section: Application Security Question: Do you subject your code to static code analysis and/or static application security testing prior to release?*	
APPL-07	Application Security	PARTIAL	COMPLIANT	COMPLIANT	MEDIUM	4	2	Vendor confirmation alone is insufficient. The SOC 2 report does not detail the specific testing processes employed (dynamic or static), nor provide evidence of adherence. Murdoch requires a summary of their process.	Control: APPL-07 Section: Application Security Question: Do you have software testing processes (dynamic or static) that are established and followed?*	Compliant Response: Yes
APPL-08	Application Security	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	3	3		Control: OPEM-01 Section: Operational & Emerging Tech Question: Do you support role-based access control (RBAC) for system administrators?	
APPL-09	Application Security	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Compliant Response: Yes	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
APPL-10	Application Security	GAP	COMPLIANT	PARTIAL	MEDIUM	3	3	The vendor's response is a simple 'Yes,' but does not provide details about the process or implemented procedures. Murdoch requires specifics as outlined in Policy 1. Further investigation is needed to determine if the stated process meets Murdoch's requirements.	Control: APPL-10 Section: Application Security Question: Do you have a process and implemented procedures for managing your software supply chain (e.g., libraries, repositories, frameworks, etc.) Guidance: Include any in-house developed or contract development.	Request detailed documentation of the software supply chain management process, including specific controls and implementation details.
APPL-11	Application Security	PARTIAL	COMPLIANT	PARTIAL	MINOR	3	2	The vendor provides evidence of training but doesn't specify the scope or frequency. Murdoch requires mandatory annual refresher training as per PPPR-12. The SOC 2 report only mentions 'annual refreshers' without detail.		Request further details regarding the training program, including duration, content covered, and frequency of delivery to ensure alignment with Murdoch's requirements for ongoing security awareness.
APPL-12	Application Security	PARTIAL	COMPLIANT	PARTIAL	MINOR	3	2	The vendor's affirmation lacks specific details regarding the secure coding techniques employed. While they state 'yes,' it doesn't demonstrate adherence to Murdoch University's policy requirements (as evidenced by APPL-11 and APPL-06). Further investigation is needed to understand the scope of their secure coding practices.		Request further documentation detailing the specific secure coding techniques utilized, including evidence of training for developers (as per APPL-11) and details on static code analysis/testing processes (APPL-03 & APPL-07).

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
APPL-14	Application Security	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Control: APPL-14 Section: Application Security Question: Do you have a fully implemented policy or procedure that details how your employees obtain administrator access to institutional instance of the application? Compliant Response: Yes	
AAAI-01	Access Control	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2		Yes	
AAAI-02	Access Control	COMPLIANT	COMPLIANT	COMPLIANT	HIGH	4	3			
AAAI-03	Access Control	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2		Compliant Response: Yes	
AAAI-04	Access Control	GAP	GAP	GAP	MEDIUM	4	2	Vendor evidence does not corroborate the claim of password complexity enforcement. The SOC 2 report mentions system controls but doesn't explicitly state that password complexity is enforced according to Murdoch University's policy (Policy 4). HECVAT requires a 'Yes' response for this control.		Vendor must provide detailed evidence demonstrating implementation of password complexity requirements, aligning with Murdoch University's Password Policy. This includes specifics on minimum length, character restrictions, and enforcement mechanisms.
AAAI-05	Access Control	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2		Do you have documented password/passphrase reset procedures that are currently implemented in the system and/or customer support?*	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AAAI-06	Access Control	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	4	1		Compliant Response: Yes	
AAAI-07	Access Control	GAP	GAP	INSUFFICIENT_EVIDENCE	EXTREME	5	3	CONTEXT A requires a definitive statement about the absence of hardcoded passwords/passphrases. The vendor's response alone is insufficient to confirm compliance. Vendor evidence does not provide corroborating details.	Policy 1: hecvat_template Access Control - Question: Are there any passwords/passphrases hard-coded into your systems or solutions?*	Request detailed documentation from the vendor outlining their systems architecture and security controls, specifically addressing how password management is handled. Obtain evidence demonstrating the absence of hardcoded credentials.
AAAI-08	Access Control	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	5	1		Compliant Response: No	
AAAI-09	Access Control	COMPLIANT	COMPLIANT	COMPLIANT	HIGH	4	3		Are audit logs available for all changes to the network, firewall, IDS, and IPS systems?	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AAAI-10	Access Control	COMPLIANT	COMPLIANT	COMPLIANT	HIGH	4	3		Control: AAAI-10 Section: Access Control Question: Describe or provide a reference to the (a) system capability to log security/authorization changes, as well as user and administrator security events (i.e., physical or electronic), such as login failures, access denied, changes accepted; and (b) all requirements necessary to implement logging and monitoring on the system. Include (c) information about SIEM/log collector usage.*	
AAAI-11	Access Control	GAP	PARTIAL	PARTIAL	HIGH	4	3	The vendor's 'Yes' response is insufficient. Murdoch University policy (Policy 1 & Policy 3) requires a detailed explanation of log retention periods (12 months), protection mechanisms (SIEM forwarding and non-repudiation), and access controls for auditors or administrators. The vendor has not provided this information, leaving the risk assessment incomplete.		Request further documentation from the vendor outlining their specific logging practices, data protection measures, and access control procedures to ensure alignment with Murdoch University's ICT Security Standard.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AAAI-12	Access Control	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	5	1		Does your application support integration with other authentication and authorization systems?	
AAAI-13	Access Control	COMPLIANT	COMPLIANT	COMPLIANT	LOW	3	1		Do you allow the customer to specify attribute mappings for any needed information beyond a user identifier? (e.g., Reference eduPerson, ePPA/ePPN/ePE)	
AAAI-14	Access Control	PARTIAL	COMPLIANT	PARTIAL	MINOR	3	2	Vendor evidence lacks specific details on the directory integration method. While stating 'Yes' to support is sufficient for HECVAT compliance, Murdoch University requires a more detailed understanding of how this integration functions and its security implications.	Does your application support directory integration for user accounts?	Request further clarification from the vendor regarding the specific directory services supported (e.g., Active Directory, Azure AD) and the authentication protocols used.
AAAI-15	Access Control	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	5	1		Yes	
AAAI-16	Access Control	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	3	3		10.2 User Identification (a) Students are assigned a userid (i.e. student number) at the time they are offered a place at the University; (b) Employees of the University are assigned a userid (i.e. staff)	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AAAI-17	Access Control	GAP	GAP	INSUFFICIENT_EVIDENCE	MEDIUM	3	3	The vendor's response indicates a lack of support for multifactor authentication, which contradicts Murdoch University's policy requiring MFA unless technically or procedurally restricted (Policy 5). This represents a significant gap in security.	2.7. All authentications must have Mutli Factor Authentication enabled unless it is not possible due to technical or procedural restrictions. All exceptions must be approved and registered by the IT Security team or delegate.	Require the vendor to implement and demonstrate support for MFA solutions that align with Murdoch University's requirements. Further investigation is needed to determine if any exceptions are permissible, but these must be formally approved.
AAAI-18	Access Control	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	3	3		Policy 2.2.1: Devices must be configured to "lock" or log out and require a user to re-authenticate if left unattended for more than twenty (20) minutes, except in the following cases:	
CHNG-01	Change Management	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2		Control: CHNG-01 Section: Change Management Question: Will the institution be notified of major changes to your environment that could impact the institution's security posture?*	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
CHNG-02	Change Management	PARTIAL	COMPLIANT	PARTIAL	MEDIUM	4	2	The vendor's confirmation is insufficient as it lacks detail on the process for verifying compatibility and managing potential conflicts. Context A requires a fully implemented solution support strategy outlining version support and customer utilization.	Guidance: List the current version you support and what percentage of customers are utilizing that version.	Request further documentation detailing the system's change management processes, specifically regarding third-party library support and version compatibility.
CHNG-03	Change Management	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2		Control: CHNG-03 Section: Change Management Question: Do you have an implemented system configuration management process (e.g., secure "gold" images, etc.)* Compliant Response: Yes	
CHNG-04	Change Management	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Control: CHNG-15 Section: Change Management Question: Do procedures exist to provide that emergency changes are documented and authorized (including after-the-fact approval)?	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
CHNG-05	Change Management	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	The vendor's response is a simple 'Yes,' but CONTEXT A outlines a more detailed process including authorization, impact analysis, testing and validation. The vendor evidence does not provide sufficient detail to confirm these elements are implemented. While the vendor claims compliance, it's unclear if all aspects of Murdoch University's policy are met.	Control: CHNG-06; Section: Change Management; Question: Does your change management process verify that all required third-party libraries and dependencies are still supported with each major change?	Request further clarification from the vendor regarding the specific procedures they employ for authorization, impact analysis, testing and validation. Obtain documentation demonstrating adherence to Murdoch University's Change Management Guidelines.
CHNG-06	Change Management	GAP	GAP	INSUFFICIENT_EVIDENCE	HIGH	4	3	The vendor's response directly contradicts Murdoch University's policy (Policy 1 & 2) which mandates verification of third-party library support during changes. This represents a significant risk to system stability and security.	Control: CHNG-06 Section: Change Management Question: Does your change management process verify that all required third-party libraries and dependencies are still supported with each major change?	Require the vendor to implement a process for verifying ongoing support for all third-party libraries and dependencies associated with this system, documenting these efforts as part of their SOC 2 report.
CHNG-07	Change Management	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Control: CHNG-07 Section: Change Management Question: Do you have policy and procedure, currently implemented, managing how critical patches are applied to all systems and applications?	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
CHNG-08	Change Management	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Control: CHNG-08 Section: Change Management Question: Have you implemented policies and procedures that guide how security risks are mitigated until patches can be applied?	
CHNG-09	Change Management	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Control: CHNG-09 Section: Change Management Question: Do clients have the option to not participate in or postpone an upgrade to a new release?	
CHNG-10	Change Management	COMPLIANT	COMPLIANT	COMPLIANT	LOW	3	1		Control: CHNG-10 Section: Change Management Question: Do you have a fully implemented solution support strategy that defines how many concurrent versions you support?	
CHNG-11	Change Management	COMPLIANT	COMPLIANT	COMPLIANT	LOW	3	1		Control: CHNG-11 Section: Change Management Question: Do you have a release schedule for product updates?	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
CHNG-12	Change Management	PARTIAL	COMPLIANT	PARTIAL	MEDIUM	3	3	While the vendor states they have a roadmap, no evidence was provided to corroborate this claim. Murdoch University requires documented proof of a technology roadmap for at least two years.	Control: CHNG-12, Section: Change Management, Question: Do you have a technology roadmap, for at least the next two years, for enhancements and bug fixes for the solution being assessed?	Request and review the vendor's technology roadmap documentation to verify its scope and timeline.
CHNG-13	Change Management	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Control: CHNG-13 Section: Change Management Question: Can solution updates be completed without institutional involvement (i.e., technically or organizationally) ? Compliant Response: Yes	
CHNG-14	Change Management	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Control: CHNG-14 Section: Change Management Question: Are upgrades or system changes installed during off-peak hours or in a manner that does not impact the customer?	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
CHNG-15	Change Management	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Control: CHNG-15 Section: Change Management Question: Do procedures exist to provide that emergency changes are documented and authorized (including after-the-fact approval)?	
CHNG-16	Change Management	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	The vendor's 'Yes' response lacks detail regarding the scope and implementation of their systems management strategy. Context A requires a detailed description including servers, appliances, cloud services, applications, and mobile devices. The SOC 2 report (Vendor Evidence 1) mentions complementary user entity controls but doesn't confirm a comprehensive strategy for Murdoch University.		Request further documentation detailing the vendor's systems management strategy, specifically outlining how it addresses servers, appliances, cloud services, applications, and mobile devices. Obtain evidence of documented processes and configurations.
DATA-01	Data Security	INSUFFICIENT EVIDENCE	NOT_ASSESSED	INSUFFICIENT EVIDENCE	NOT_SCORED	0	0	LLM response could not be parsed.		Add relevant policy document and re-assess.
DATA-02	Data Security	COMPLIANT	COMPLIANT	COMPLIANT	EXTREME	5	3		4.3.2 Encrypt the data stream and provide a secure data path to critical systems;	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
DATA-03	Data Security	COMPLIANT	COMPLIANT	COMPLIANT	HIGH	4	3		Control: DATA-23 Section: Data Security Question: Do you have a cryptographic key management process (generation, exchange, storage, safeguards, use, vetting, and replacement) that is documented and currently implemented, for all system components (e.g., database, system, web, etc.)?	
DATA-04	Data Security	COMPLIANT	COMPLIANT	COMPLIANT	HIGH	4	3		Do all cryptographic modules in use in your solution conform to the Federal Information Processing Standards (FIPS PUB 140-2 or 140-3)?*	
DATA-05	Data Security	COMPLIANT	COMPLIANT	COMPLIANT	HIGH	4	3			
DATA-06	Data Security	COMPLIANT	COMPLIANT	COMPLIANT	HIGH	4	3		6.2. Business owners must monitor and review external provider's services at	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
DATA-07	Data Security	GAP	GAP	INSUFFICIENT_EVIDENCE	EXTREME	5	4	The vendor's response directly contradicts Murdoch University's policy (DATA-07) which explicitly states that backups containing institutional data should *never* leave the institution's data zone. This represents a significant risk to data security and compliance.	Control: DATA-07 Section: Data Security Question: Do backups containing the institution's data ever leave the institution's data zone either physically or via network routing?*	Require the vendor to provide detailed documentation demonstrating how they prevent backups from leaving the designated data zone, including specific technical controls and monitoring procedures. Further investigation is needed to understand the root cause of this discrepancy.
DATA-08	Data Security	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2		Compliant Response: Yes	
DATA-09	Data Security	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	3	3		PDAT-04: Given the vast number of privacy regulations and laws throughout the world, it is important to know when, where, why, and how institutional data is being shared outside the United States. This information is necessary to ensure compliance and to protect the institutional data.	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
DATA-10	Data Security	GAP	GAP	INSUFFICIENT_EVIDENCE	HIGH	3	4	The vendor's claim of being able to extract a backup needs further validation. Murdoch University policy (PDAT-04) requires careful consideration of data sharing outside the US and mandates detailed documentation. The SOC 2 report does not provide sufficient detail on how backups are handled or secured, particularly regarding compliance with international regulations. The vendor's response lacks specifics about backup procedures, encryption methods, and controls to prevent unauthorized extraction.		Request further details from the vendor regarding their backup procedures, including location of backups, security measures employed (encryption, access controls), and adherence to Murdoch University's data sharing policies. Conduct a deeper review of the SOC 2 report to assess the robustness of their controls.
DATA-11	Data Security	GAP	PARTIAL	PARTIAL	HIGH	3	4	Vendor confirmation lacks specific details regarding the scope of 'all' operating system software, utilities, security software, application software, and data files. Without further clarification and evidence demonstrating comprehensive coverage, it's difficult to assess full compliance with Murdoch University's requirements for disaster recovery.	2.13. Critical IT systems must have disaster recovery plans that are documented and regularly tested.	Request detailed documentation from the vendor outlining the specific components included in their backups, referencing relevant sections of Murdoch University's CMDB and Data Classification Policy.
DATA-12	Data Security	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Control: DATA-07 Section: Data Security Question: Do backups containing the institution's data ever leave the institution's data zone either physically or via network routing?	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
DATA-13	Data Security	COMPLIANT	COMPLIANT	COMPLIANT	HIGH	3	4		Control: DATA-07 Section: Data Security Question: Do backups containing the institution's data ever leave the institution's data zone either physically or via network routing?	
DATA-14	Data Security	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	3	3		DATA-23: Do you have a cryptographic key management process (generation, exchange, storage, safeguards, use, vetting, and replacement) that is documented and currently implemented, for all system components (e.g., database, system, web, etc.)?	
DATA-15	Data Security	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	The vendor's confirmation of a media handling process is insufficient. Murdoch University policy (ICT Security Policy 1.pdf) requires a *documented* and *implemented* process that meets established business needs and regulatory requirements, including end-of-life, repurposing, and data-sanitization procedures. The vendor has not provided evidence to demonstrate this documentation or implementation.	Control: DATA-15 Section: Data Security Question: Do you have a media handling process that is documented and currently implemented that meets established business needs and regulatory requirements, including end-of-life, repurposing, and data-sanitization procedures?	Request detailed documentation of the media handling process, including specific procedures for end-of-life, repurposing, and data sanitization. Obtain evidence of current implementation.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
DATA-16	Data Security	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	3	3		Control: DATA-16 Section: Data Security Question: Does the process described in DATA-15 adhere to DoD 5220.22-M and/or NIST SP 800-88 standards? Compliant Response: Yes	
DATA-17	Data Security	COMPLIANT	COMPLIANT	COMPLIANT	LOW	1	1			
DATA-18	Data Security	GAP	GAP	GAP	MEDIUM	3	3	The vendor's response is a simple 'Yes' without detailing the strategy. Murdoch University policy (Policy 1) requires a *documented and currently implemented* strategy. The vendor evidence does not provide sufficient detail to confirm compliance with this requirement.	Control: DATA-18 Section: Data Security Question: Do you have a documented and currently implemented strategy for securing employee workstations when they work remotely (i.e., not in a trusted computing environment)?	Request detailed documentation of the remote workstation security strategy, including specific controls employed, frequency of monitoring, and incident response procedures.
DATA-19	Data Security	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Compliant Response: Yes	
DATA-20	Data Security	GAP	GAP	INSUFFICIENT EVIDENCE	MEDIUM	3	3	The vendor's assertion of 'Yes' does not align with Murdoch University's policy requirements (PDAT-03 and PDAT-07) which mandate careful consideration of data combinations and access controls. The SOC 2 report provides limited detail on how ownership is maintained, requiring further investigation to confirm compliance.		Request detailed documentation from the vendor outlining their processes for maintaining ownership rights, including specific procedures for data classification, access control, and audit trails. Verify that these processes align with Murdoch University's internal policies.
DATA-21	Data Security	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	3	3			

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
DATA-22	Data Security	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	The vendor's response is a simple 'Yes' without providing details about backup schedules, storage locations, or security measures. Policy 5 and 4 state that devices kept in a physical secured space not accessible by unauthorized users are exempt from this standard, but does not cover backups. The SOC 2 report mentions data encryption and regular backups but lacks specifics regarding Murdoch University's defined schedule and secure storage requirements.	5.3 Storage devices held by Information Technology Services for deployment, transfer, repair or disposal will be recorded, securely stored	Request detailed documentation outlining the backup schedules, storage locations (including physical security), encryption methods used, and access controls for these backup copies to ensure alignment with Murdoch University's ICT Security Standard.
DATA-23	Data Security	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Control: DATA-23 Section: Data Security Question: Do you have a cryptographic key management process (generation, exchange, storage, safeguards, use, vetting, and replacement) that is documented and currently implemented, for all system components (e.g., database, system, web, etc.)? Guidance: Summarize your cryptographic key management process.	
DCTR-02	Data Center	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Is a SOC 2 Type 2 report available for the hosting environment?	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
DCTR-03	Data Center	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Policy 4: hecvat_template Data Center - Question: Are your primary and secondary data centers geographically diverse?	
DCTR-04	Data Center	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	5	1		Are the data centers staffed 24 hours a day, seven days a week (i.e., 24 x 7 x 365)?	
DCTR-05	Data Center	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Control: DCTR-05 Section: Data Center Question: Are your servers separated from other companies via a physical barrier, such as a cage or hard walls? Compliant Response: Yes	
DCTR-06	Data Center	GAP	COMPLIANT	PARTIAL	HIGH	4	3	The vendor's 'Yes' response does not provide sufficient detail to confirm full compliance. Policy A states that a physical barrier *fully* encloses the space. The vendor has not demonstrated this is the case.	Control: DCTR-06 Section: Data Center Question: Does a physical barrier fully enclose the physical space, preventing unauthorized physical contact with any of your devices?	Request further documentation from the vendor detailing the specific type of barrier used and its effectiveness in preventing unauthorized access. Obtain photographic evidence if possible.
DCTR-07	Data Center	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Are your primary and secondary data centers geographically diverse?	
DCTR-08	Data Center	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Compliant Response: Yes	
DCTR-09	Data Center	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Compliant Response: Yes	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
DCTR-10	Data Center	GAP	COMPLIANT	PARTIAL	HIGH	4	3	Vendor response is a simple 'Yes' without detail on the testing frequency or scope. Murdoch University policy (Policy 5) requires documented disaster recovery plans that are regularly tested. The vendor's response does not demonstrate sufficient evidence of regular testing.	2.13. Critical IT systems must have disaster recovery plans that are documented and regularly tested.	Request further details regarding the testing methodology, frequency, and scope to ensure alignment with Murdoch University's requirements for disaster recovery planning.
DCTR-11	Data Center	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Does the center where the data will reside have cooling and fire-suppression systems that are active and regularly tested?	
DCTR-12	Data Center	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Do you have Internet Service Provider (ISP) redundancy?	
DCTR-13	Data Center	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Does every data center where the institution's data will reside have multiple telephone company or network provider entrances to the facility?	
DCTR-14	Data Center	GAP	GAP	GAP	HIGH	3	4	Vendor does not meet Murdoch University's policy requiring MFA for administrative accounts. This represents a significant risk as it leaves systems vulnerable to unauthorized access.		Require the vendor to implement MFA for all administrative accounts and provide evidence of implementation within 30 days.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
DCTR-15	Data Center	GAP	COMPLIANT	PARTIAL	MEDIUM	3	3	The vendor's confirmation lacks specifics regarding *which* hardening tools or pre-hardened images are being utilized. Simply stating 'yes' does not demonstrate adherence to Murdoch University's requirement for detailed documentation and validation of the chosen solutions. Further investigation is needed.	Are you using your cloud provider's available hardening tools or pre-hardened images?	Request specific details about the cloud provider's hardening tools and pre-hardened images employed, including evidence of their implementation and effectiveness.
DCTR-16	Data Center	GAP	GAP	INSUFFICIENT_EVIDENCE	MEDIUM	3	3	The vendor's response aligns with the HECVAT compliant response of 'No'. However, Context A requires a description of key management practices. The vendor evidence does not provide sufficient detail to confirm this requirement is met. It only states that data is encrypted and backed up but doesn't elaborate on the process for managing encryption keys.		Request further documentation detailing the vendor's cryptographic key management processes, including generation, exchange, storage, safeguards, use, vetting, and replacement procedures as outlined in Context A.
FIDP-01	Firewall & IDS/IPS	GAP	COMPLIANT	PARTIAL	HIGH	4	3	CONTEXT B does not provide sufficient detail to corroborate the vendor's claim. While they state they use a SPI firewall, it doesn't demonstrate how this aligns with Murdoch University's requirements as outlined in POLICY 1 (HECVAT_TEMPLATE Firewall & IDS/IPS). Further investigation is needed.	Control: FIDP-04	Request detailed documentation from the vendor outlining their SPI firewall implementation and its configuration to ensure alignment with Murdoch's security policies. Specifically, request details on how it performs stateful inspection and packet filtering.
FIDP-02	Firewall & IDS/IPS	GAP	COMPLIANT	PARTIAL	MEDIUM	4	2	Vendor response is a simple 'Yes' and does not provide details of the documented policy. Context A requires a documented policy, but doesn't specify content. The vendor has not provided evidence of this policy.		Request documentation of the firewall change request policy from the vendor to verify compliance with Murdoch University's requirements.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
FIDP-03	Firewall & IDS/IPS	GAP	COMPLIANT	PARTIAL	MEDIUM	4	2	Vendor did not provide evidence to corroborate the implementation of a network-based intrusion detection system. Murdoch University policy (FIDP-04) requires confirmation of this control.	Control: FIDP-04	Request detailed documentation and evidence demonstrating the deployment and operational status of the network-based intrusion detection system.
FIDP-04	Firewall & IDS/IPS	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2			
FIDP-05	Firewall & IDS/IPS	GAP	COMPLIANT	PARTIAL	MEDIUM	4	2	Vendor response is 'Yes' but CONTEXT A requires specific details about logging implementation (retention, access for administrators/auditors). Vendor evidence does not provide sufficient detail to confirm compliance. The HECVAT compliant response is 'Yes', however the policy requires more than a simple affirmation.		Request further documentation from the vendor detailing log retention policies, administrator/auditor access procedures, and how logs support compliance and incident response.
FIDP-06	Firewall & IDS/IPS	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	3	3		Control: CHNG-15 Section: Change Management Question: Do procedures exist to provide that emergency changes are documented and authorized (including after-the-fact approval)?	
FIDP-07	Firewall & IDS/IPS	GAP	COMPLIANT	PARTIAL	MINOR	3	2	Vendor response is affirmative but lacks detail regarding implementation and monitoring as required by Policy 10 (FIDP-10). The vendor's SOC 2 report does not provide sufficient evidence of 24x7x365 intrusion monitoring. Murdoch requires a brief summary of its implementation.	Policy 10: In addition to stating your intrusion monitoring strategy, provide a brief summary of its implementation.	Request further details from the vendor regarding their intrusion monitoring strategy and implementation, including documentation demonstrating 24/7/365 coverage.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
FIDP-08	Firewall & IDS/IPS	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2			
FIDP-09	Firewall & IDS/IPS	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2			
FIDP-10	Firewall & IDS/IPS	GAP	COMPLIANT	PARTIAL	MINOR	3	2	Vendor evidence is lacking. Context A requires a brief summary of implementation, which the vendor did not provide. While the response 'Yes' aligns with HECVAT's compliant response, it lacks supporting details to confirm compliance.	Control: FIDP-10 Section: Firewall & IDS/IPS Question: Is intrusion monitoring performed internally or by a third-party service? Guidance: In addition to stating your intrusion monitoring strategy, provide a brief summary of its implementation.	Request further documentation detailing the intrusion monitoring strategy and its implementation from the vendor.
FIDP-11	Firewall & IDS/IPS	GAP	COMPLIANT	PARTIAL	MEDIUM	3	3	The vendor's response aligns with the HECVAT compliant response (Yes). However, Context A requires a brief summary of its implementation. The vendor evidence does not provide this detail, leaving the level of assurance uncertain.	Control: FIDP-11 Section: Firewall & IDS/IPS Question: Do you monitor for intrusions on a 24 x 7 x 365 basis? Compliant Response: Yes	Request further details on the implementation strategy for 24x7x365 intrusion monitoring from the vendor to assess the completeness of their compliance.
PPPR-01	Policies, Processes & Procedures	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2			
PPPR-02	Policies, Processes & Procedures	GAP	GAP	INSUFFICIENT EVIDENCE	HIGH	4	3	The vendor states non-compliance with Murdoch's policies. Context A requires confirmation of compliance. Vendor evidence does not provide sufficient detail to confirm alignment with institutional requirements.		Request further clarification from the vendor regarding their specific processes for managing user access and ensuring adherence to Murdoch University's privacy and data protection policies. Obtain detailed documentation outlining these controls.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
PPPR-03	Policies, Processes & Procedures	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	5	1			
PPPR-04	Policies, Processes & Procedures	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	3	3		Compliant Response: Yes	
PPPR-05	Policies, Processes & Procedures	PARTIAL	COMPLIANT	COMPLIANT	MINOR	3	2	Vendor confirmation is provided but lacks detail regarding the specific processes and procedures within the SDLC. Further investigation would be needed to fully assess alignment with Murdoch's requirements.		
PPPR-06	Policies, Processes & Procedures	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Policies, Processes & Procedures Control: PPPR-06 Section: Policies, Processes & Procedures Question: Do you perform background screenings or multi-state background checks on all employees prior to their first day of work? Compliant Response: Yes	
PPPR-07	Policies, Processes & Procedures	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2			
PPPR-08	Policies, Processes & Procedures	COMPLIANT	COMPLIANT	COMPLIANT	LOW	3	1			

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
PPPR-09	Policies, Processes & Procedures	GAP	COMPLIANT	PARTIAL	MINOR	3	2	The vendor's response is a simple 'Yes,' but lacks detail regarding *how* information security principles are designed into the product lifecycle. Context A requires demonstrating this design-in process. The SOC 2 report mentions training and procedures, but doesn't explicitly state how these relate to the lifecycle.	Policies, Processes & Procedures	Request further clarification from the vendor detailing their specific processes for integrating information security throughout the product lifecycle. Specifically ask for examples of how security is considered during requirements gathering, design, development, testing, and deployment.
PPPR-10	Policies, Processes & Procedures	INSUFFICIENT EVIDENCE	NOT_ASSESSED	INSUFFICIENT EVIDENCE	NOT_SCORED	0	0	LLM response could not be parsed.		Add relevant policy document and re-assess.
PPPR-11	Policies, Processes & Procedures	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Do you have an information security awareness program?	
PPPR-12	Policies, Processes & Procedures	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2			
PPPR-13	Policies, Processes & Procedures	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	3	3			
PPPR-14	Policies, Processes & Procedures	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Control: PPPR-14 Section: Policies, Processes & Procedures Question: Do you have documented, and currently implemented, internal audit processes and procedures?	
PPPR-15	Policies, Processes & Procedures	GAP	COMPLIANT	PARTIAL	MINOR	3	2	Vendor confirmation is insufficient. Context A requires a 'Yes' response but does not specify the nature or scope of these controls. Further investigation is needed to determine if the vendor's policies meet Murdoch University's requirements.		Request detailed documentation outlining the vendor's physical security controls and policies, including specific measures implemented and how they align with Murdoch University's expectations.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
HFIH-01	Incident Response	GAP	COMPLIANT	PARTIAL	MINOR	3	2	The vendor's response is a simple 'Yes,' but lacks detail regarding the plan's scope, procedures, and team composition as outlined in Murdoch University's policy. The SOC 2 report does not provide sufficient evidence of a robust IRP.		Request further documentation detailing the incident response plan, including its scope, procedures, escalation paths, and contact information for the incident response team.
HFIH-02	Incident Response	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2			
HFIH-03	Incident Response	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	5	1		Compliant Response: Yes	
HFIH-04	Incident Response	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	3	3		Control: HFIH-04 Section: Incident Response Question: Do you carry cyber-risk insurance to protect against unforeseen service outages, data that is lost or stolen, and security incidents?	
VULN-01	Vulnerability Management	GAP	PARTIAL	PARTIAL	HIGH	4	3	The vendor's response is a simple 'Yes,' but CONTEXT A requires specifics about the scanning process (authenticated user account) and remediation. The SOC 2 report doesn't provide sufficient detail to confirm compliance with Murdoch University's requirements. It only states that systems are validated after containment, which isn't equivalent to proactive scanning prior to releases.	Control: VULN-01 Section: Vulnerability Management Question: Are your systems and applications scanned with an authenticated user account for vulnerabilities (that are remediated) prior to new releases?*	Request further details from the vendor regarding their vulnerability scanning process, including authentication methods, remediation timelines, and evidence of patching activities.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
VULN-02	Vulnerability Management	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2		Control: VULN-02 Section: Vulnerability Management Question: Will you provide results of application and system vulnerability scans to the institution?*	
VULN-03	Vulnerability Management	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2		Will you allow the institution to perform its own vulnerability testing and/or scanning of your systems and/or application, provided that testing is performed at a mutually agreed upon time and date?*	
VULN-04	Vulnerability Management	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Control: VULN-04 Section: Vulnerability Management Question: Have your systems and applications had a third-party security assessment completed in the last year?	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
VULN-05	Vulnerability Management	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Control: VULN-05 Section: Vulnerability Management Question: Do you regularly scan for common web application security vulnerabilities (e.g., SQL injection, XSS, XSRF, etc.)? Guidance: Ensure that all elements of VULN-05 are clearly stated in your response.	
VULN-06	Vulnerability Management	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Are your systems and applications regularly scanned externally for vulnerabilities?	
OPEM-01	Operational & Emerging Tech	GAP	GAP	INSUFFICIENT_EVIDENCE	MEDIUM	3	3	The vendor explicitly states they do not support RBAC, directly contradicting Murdoch University's policy requirement (Policy 1 and Policy 2) as outlined in Context A. This represents a significant gap in security controls.		Require the vendor to implement and demonstrate RBAC capabilities immediately.
OPEM-02	Operational & Emerging Tech	COMPLIANT	COMPLIANT	COMPLIANT	LOW	3	1			

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
OPEM-03	Operational & Emerging Tech	GAP	GAP	INSUFFICIENT_EVIDENCE	MEDIUM	3	3	The vendor's response directly contradicts the requirement outlined in Policy 1 and Policy 2 of Context A. The vendor has not provided the necessary system architecture diagrams or data communications details as requested.	Control: OPEM-03 Section: Operational & Emerging Tech Question: Can you provide overall system and/or application architecture diagrams including a full description of the data communications architecture for all components of the system?	Request detailed documentation and architectural diagrams from the vendor to demonstrate compliance with this control.
OPEM-04	Operational & Emerging Tech	COMPLIANT	COMPLIANT	COMPLIANT	LOW	1	1			
OPEM-05	Operational & Emerging Tech	GAP	GAP	GAP	MEDIUM	3	3	The vendor's response directly contradicts Murdoch University's policy (CONTEXT A) which requires remote actions and changes to be logged or otherwise visible. Vendor evidence does not corroborate this requirement.	Control: OPEM-05 Section: Operational & Emerging Tech Question: Are your remote actions and changes logged or otherwise visible to the campus? (IF YES to OPAP-06)	Vendor must provide detailed documentation demonstrating how they log and monitor remote access activities, ensuring visibility to the campus as required by Murdoch University's policies.
OPEM-06	Operational & Emerging Tech	GAP	GAP	INSUFFICIENT_EVIDENCE	HIGH	3	4	The vendor's response contradicts the explicit requirement in Policy 1 and Policy 2 which state 'Yes'. The SOC 2 report provides some details about access controls but doesn't confirm FERPA compliance. This represents a significant gap.	Control: OPEM-06 Section: Operational & Emerging Tech Question: If you maintain remote access to the system, will you handle data in a FERPA-compliant manner? Compliant Response: Yes	Require the vendor to provide detailed documentation demonstrating FERPA compliance for remote access, including specific security measures implemented.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
OPEM-07	Operational & Emerging Tech	GAP	GAP	GAP	MINOR	3	2	The vendor's response contradicts Murdoch University's policy (Policy 1 & 2) which explicitly requires support for campus status monitoring via SNMPv3. The vendor's negative response indicates a significant gap in compliance.		Require the vendor to provide detailed documentation outlining their monitoring capabilities and justification for not supporting SNMPv3, or identify an alternative solution that meets Murdoch University's requirements.
OPEM-08	Operational & Emerging Tech	GAP	NOT_ASSESSED	GAP	MINOR	3	2	The vendor did not provide any information regarding monitoring safeguards. Murdoch University policy (Policy 1) requires a description of such safeguards. Since no relevant policy exists in Context A, it cannot be assessed.		
OPEM-09	Operational & Emerging Tech	GAP	NOT_ASSESSED	INSUFFICIENT EVIDENCE	MINOR	3	2	The vendor did not provide a response to the requirement. Without any information about their experience in this area, it's impossible to assess alignment with Murdoch University's policy.		
OPEM-10	Operational & Emerging Tech	GAP	GAP	GAP	MINOR	3	2	The vendor's response contradicts Murdoch University's policy (Policy 1 & 2) which explicitly states they have existing higher education customers. The SOC 2 report does not provide sufficient evidence to corroborate the vendor's claim.		Require the vendor to provide verifiable documentation demonstrating their lack of existing higher education customer engagements, or reconsider this vendor for Murdoch University's needs.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AIGN-01	AI Governance	GAP	COMPLIANT	PARTIAL	MEDIUM	4	2	Vendor evidence is lacking. Context A requires examples like NIST AI RMF, OWASP Top 10, RAFT, or MITRE ATLAS to demonstrate the risk model. The vendor's 'Yes' response does not provide any detail about the model itself or how it aligns with these examples.	Control: AIGN-01 Section: AI Governance Question: Does your solution have an AI risk model when developing or implementing your solution's AI model?* Guidance: Examples include NIST AI RMF, OWASP Top 10, RAFT, and MITRE ATLAS.	Request further documentation detailing the specific AI risk model employed and its alignment with recognized frameworks like NIST AI RMF or OWASP Top 10.
AIGN-02	AI Governance	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2		Control: AIGN-02 Section: AI Governance Question: Can your solution's AI features be disabled by tenant and/or user?*	
AIGN-03	AI Governance	GAP	COMPLIANT	PARTIAL	MEDIUM	4	2	Vendor provides only a 'Yes' response without supporting evidence or details about the training provided. Murdoch University requires documentation of responsible AI training and its frequency (Policy 1). The vendor's response does not meet this requirement.	Guidance: Provide the responsible AI training provided to your staff and its frequency.	Request detailed information regarding the responsible AI training program, including content, duration, and frequency of delivery to staff.
AIGN-04	AI Governance	PARTIAL	COMPLIANT	COMPLIANT	LOW	3	1	The vendor provided a simple 'Yes' response without detailing the capabilities, use-cases, goals, and benefits as required by Policy 1. While it aligns with HECVAT's qualitative answer requirement, it doesn't fully satisfy Murdoch's need for specific information.	Policy 1: hecvat_template AI Governance - Question: Please describe the capabilities of your solution's AI features. Guidance: Looking for the capabilities, use-case, goals, and benefits of the AI model or feature(s).	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AIGN-05	AI Governance	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Control: AIGN-05 Section: AI Governance Question: Does your solution support business rules to protect sensitive data from being ingested by the AI model? Compliant Response: Yes	
AIPL-01	AI Policy	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2		Control: AIPL-01 Section: AI Policy Question: Are your AI developer's policies, processes, procedures, and practices across the organization related to the mapping, measuring, and managing of AI risks conspicuously posted, unambiguous, and implemented effectively?*	
AIPL-02	AI Policy	GAP	PARTIAL	PARTIAL	HIGH	4	3	CONTEXT A requires documentation and policies around measuring AI risk. Vendor response is a simple 'Yes' without supporting evidence or details of the measurement process. The SOC 2 report mentions a risk matrix but doesn't demonstrate how risks are identified and measured.	Guidance: Looking for documentation and policies around measuring AI risk.	Request further detail on the vendor's AI risk measurement methodology, including specific tools, techniques, and metrics used. Require documentation demonstrating the risk model in place.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AIPL-03	AI Policy	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2		In the event of an incident, can your solution's AI features be disabled in a timely manner?	
AIPL-04	AI Policy	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2		If disabled because of an incident, can your solution's AI features be re-enabled in a timely manner?	
AIPL-05	AI Policy	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	3	3		Control: AIPL-05 Section: AI Policy Question: Do you have documented technical and procedural processes to address potential negative impacts of AI as described by the AI Risk Management Framework (RMF)? Guidance: Looking for harm reduction as part of responsible AI development per NIST AI RMF, page 25.	
AISC-01	AI Security	GAP	GAP	INSUFFICIENT_EVIDENCE	EXTREME	4	4	The vendor's response contradicts Murdoch University's policy (CONTEXT A, AISC-01) which explicitly requires the ability to remove sensitive data from an AI model by request. This represents a significant risk to data privacy and compliance.	If sensitive data is introduced to your solution's AI model, can the data be removed from the AI model by request?	Require the vendor to provide detailed documentation outlining their process for data removal or unlearning from AI models, including evidence of successful implementation. Further investigation is needed to assess the feasibility of meeting this requirement.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AISC-02	AI Security	GAP	COMPLIANT	PARTIAL	MEDIUM	4	2	The vendor's response aligns with the HECVAT compliant response of 'No'. However, the SOC 2 report (Vendor Evidence 1 & 2) indicates a lack of specific controls to prevent user input from influencing the AI model. The guidance in Policy 1 and 2 explicitly requires clarification on this point, which the vendor has not provided.	Policy 1: hecvat_template AI Security, Question: Is user input data used to influence your solution's AI model?	Request further detail from the vendor regarding their data governance practices and how they mitigate potential influence from user inputs on the AI model. Specifically request documentation of any business rules or prediction limiters.
AISC-03	AI Security	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2		Control: AISC-03 Section: AI Security Question: Do you provide logging for your solution's AI feature(s) that includes user, date, and action taken?*	
AISC-04	AI Security	GAP	NOT_ASSESSED	GAP	MINOR	3	2	The vendor did not provide a response to the question regarding user input validation. This directly contradicts Policy 11.1.2 and 11.1.3 within ICT Security Standard 1.pdf which mandates application-level input validation and error handling.		Require the vendor to detail their user input validation process, including methods for anomaly detection and malicious input rejection.
AISC-05	AI Security	GAP	PARTIAL	PARTIAL	MINOR	3	2	The vendor's response is a simple 'Yes,' but lacks specifics regarding SAST and SBOM attestations as required by Policy 2. The evidence provided does not demonstrate these controls are in place or being actively monitored.	Policy 2: hecvat_template AI Security - Guidance: Looking for SAST (Static Application Security Testing) and SBOM (Software Bill of Materials) attestations.	Request detailed information on the vendor's SAST and SBOM processes, including documentation of recent testing results and a description of how they manage software dependencies.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AIML-01	AI/ML Data Separation	GAP	GAP	INSUFFICIENT_EVIDENCE	EXTREME	4	4	The vendor's response contradicts Murdoch University's policy (CONTEXT A) which explicitly requires separation of ML training data from production data to protect institutional information. The SOC 2 report (CONTEXT B) mentions procedures for inspecting the IPE and mapping data between systems, but doesn't confirm a separation strategy is in place.		Require vendor to provide detailed documentation outlining their data segregation practices, including anonymization techniques or exclusion strategies for institutional data used in training models. Further investigation into the implementation of this control is required.
AIML-02	AI/ML Data Separation	GAP	GAP	INSUFFICIENT_EVIDENCE	HIGH	4	3	The vendor's response directly contradicts the policy requirement to authenticate and verify ML model feedback. This poses a significant risk of model skewing and inaccurate predictions.		Require the vendor to provide detailed documentation outlining their authentication and verification processes for ML model feedback.
AIML-03	AI/ML Data Separation	GAP	GAP	GAP	HIGH	4	3	The vendor's response directly contradicts Murdoch University's policy requirement (Context A) that mandates vetting, validation, and verification of ML training data. This represents a significant risk to the integrity and reliability of the AI model.	Control: AIML-03 Section: AI/ML Data Separation Question: Is your ML training data vetted, validated, and verified before training the solution's AI model? Guidance: Looking for policies/procedures about validating and verifying any data used to train the model through validation checks and employing multiple data labelers to validate the accuracy of the data labeling.	Require the vendor to provide detailed documentation outlining their data validation processes for ML training data. Conduct further due diligence to assess the robustness of these processes.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AIML-04	AI/ML Data Separation	GAP	GAP	INSUFFICIENT EVIDENCE	MEDIUM	3	3	The vendor's response contradicts Murdoch University's policy (AIML-04) which requires monitoring and auditing of ML training data. The vendor evidence does not provide any corroborating information to support their claim.		Require the vendor to provide detailed documentation outlining their ML training data monitoring and audit procedures, demonstrating compliance with Murdoch University's requirements.
AIML-05	AI/ML Data Separation	GAP	GAP	GAP	MEDIUM	3	3	The vendor's response contradicts Murdoch University's policy (AIML-05 & AIML-01) which explicitly requires limiting access to ML training data based on a business need. Vendor evidence does not provide sufficient detail or assurance regarding this requirement.	Control: AIML-05 Section: AI/ML Data Separation Question: Have you limited access to your ML training data to only staff with an explicit business need?	Require the vendor to provide detailed documentation outlining their process for restricting access to ML training data and demonstrating compliance with Murdoch University's policy.
AIML-06	AI/ML Data Separation	GAP	GAP	GAP	MINOR	3	2	The vendor's response directly contradicts the policy guidance requiring implementation of adversarial training or other model defense mechanisms. The vendor evidence does not provide any corroborating information.	Have you implemented adversarial training or other model defense mechanisms to protect your ML-related features?	Require the vendor to detail their approach to mitigating potential adversarial attacks on their ML models, including specific techniques employed and testing procedures.
AIML-07	AI/ML Data Separation	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Control: AIML-07 Section: AI/ML Data Separation Question: Do you make your ML model transparent through documentation and log inputs and outputs? Compliant Response: Yes	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AILM-08	AI/ML Data Separation	GAP	GAP	GAP	MEDIUM	3	3	The vendor's response contradicts the Murdoch University policy requiring watermarking of ML training data to aid in incident response. This represents a significant gap in data protection.	Policy 1: hecvat_template AI/ML Data Separation - Question: Do you watermark your ML training data? Guidance: Looking for watermarking of training data to aid in your incident response. Compliant Response: Yes	Require the vendor to implement and document a robust watermarking strategy for all ML training datasets, with clear procedures for managing and responding to potential breaches involving watermark identification.
AILM-01	LLM Privileges	INSUFFICIENT EVIDENCE	NOT_ASSESSED	INSUFFICIENT EVIDENCE	NOT_SCORED	0	0	LLM response could not be parsed.		Add relevant policy document and re-assess.
AILM-03	LLM Privileges	COMPLIANT	COMPLIANT	COMPLIANT	EXTREME	5	3		Control: AILM-03 Section: LLM Privileges Question: Do any actions taken by your solution's LLM features or plugins require human intervention? Compliant Response: Yes	
AILM-04	LLM Privileges	COMPLIANT	COMPLIANT	COMPLIANT	HIGH	4	3		Do you limit multiple LLM model plugins being called as part of a single input?*	
AILM-05	LLM Privileges	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2		Policy 1: hecvat_template LLM Privileges Control: AILM-05 Section: LLM Privileges Question: Do you limit your solution's LLM resource use per request, per step, and per action?	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AILM-06	LLM Privileges	GAP	GAP	GAP	MEDIUM	3	3	The vendor's response contradicts the policy guidance which explicitly requires leveraging model tuning and validation mechanisms. The SOC 2 evidence does not provide sufficient detail to corroborate this claim.	Control: AILM-06 Section: LLM Privileges Question: Do you leverage LLM model tuning or other model validation mechanisms? Guidance: Looking for fact-checking and accuracy tuning of the LLM outputs.	Require the vendor to provide detailed documentation outlining their LLM tuning and validation processes, including specific techniques employed and results achieved.
AILM-07	LLM Privileges	GAP	NOT_ASSESSED	GAP	MEDIUM	3	3	The vendor did not respond to the question regarding taint tracing or tracking of LLM plugins. This directly contradicts the policy requirement outlined in Context A (Policy 1 & 2). Without a response, it's impossible to assess compliance.	Control: AILM-07 Section: LLM Privileges Question: Do you perform taint tracing or tracking on all plugin content related to the LLM? Guidance: Looking for taint tracing or tracking of LLM plugins to mitigate malicious inputs tuning and prompt engineering. Compliant Response: Yes	Request immediate clarification and documentation from the vendor demonstrating their implementation of taint tracing and tracking for LLM plugins.